

TryHackMe IDS Evasion Room Report

Room: IDS Evasion

This report explains my experience with the TryHackMe IDS Evasion room. I learned how to bypass IDS alerts, exploit a vulnerable Grafana service, and escalate privileges to root by using stealthy techniques and exploiting misconfigurations.

Main achievements:

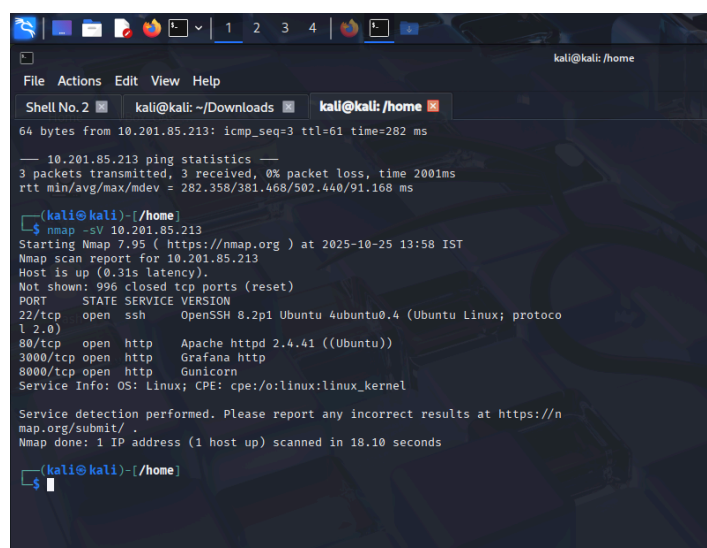
- Found Grafana running on port 3000
 - Discovered administrative credentials by reading configuration files
 - Used those credentials to access Grafana and run commands
 - Escalated privileges to root by escaping a Docker container
 - Successfully captured the root flag
-

Step 1: Reconnaissance

I started with scanning the target to find open ports and services without triggering IDS alerts. I used tools like:

- `nmap -sV TARGET_IP` to find services and versions
- Avoided fast or noisy scans to stay under the radar

The scan showed Grafana running on port 3000, which was the main entry point.



```
kali@kali: /home
File Actions Edit View Help
Shell No. 2 kali@kali: ~/Downloads kali@kali: /home
64 bytes from 10.201.85.213: icmp_seq=3 ttl=61 time=282 ms
— 10.201.85.213 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2001ms
rtt min/avg/max/mdev = 282.358/381.468/502.440/91.168 ms
(kali@kali)-[/home]
$ nmap -sV 10.201.85.213
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-25 13:58 IST
Nmap scan report for 10.201.85.213
Host is up (0.31s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
3000/tcp   open  http     Grafana http
8000/tcp   open  http     Gunicorn
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

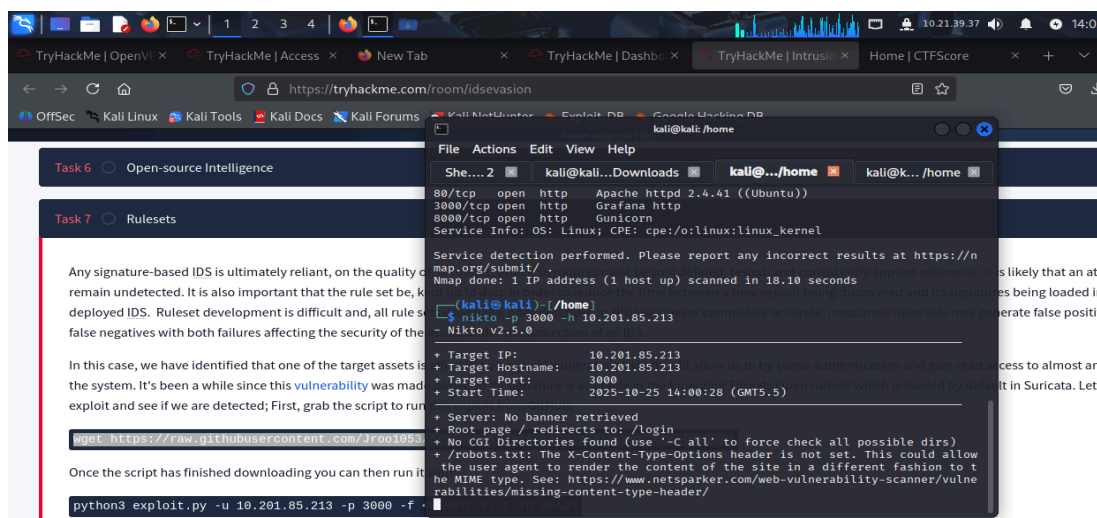
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 18.10 seconds
(kali@kali)-[/home]
$
```

Step 2: Web Enumeration and Vulnerability Discovery

Next, I scanned the Grafana service specifically using Nikto to find security weaknesses:

- Command example: `nikto -p 3000 -h TARGET_IP`
- Nikto revealed vulnerable file endpoints where Grafana served configuration and other files

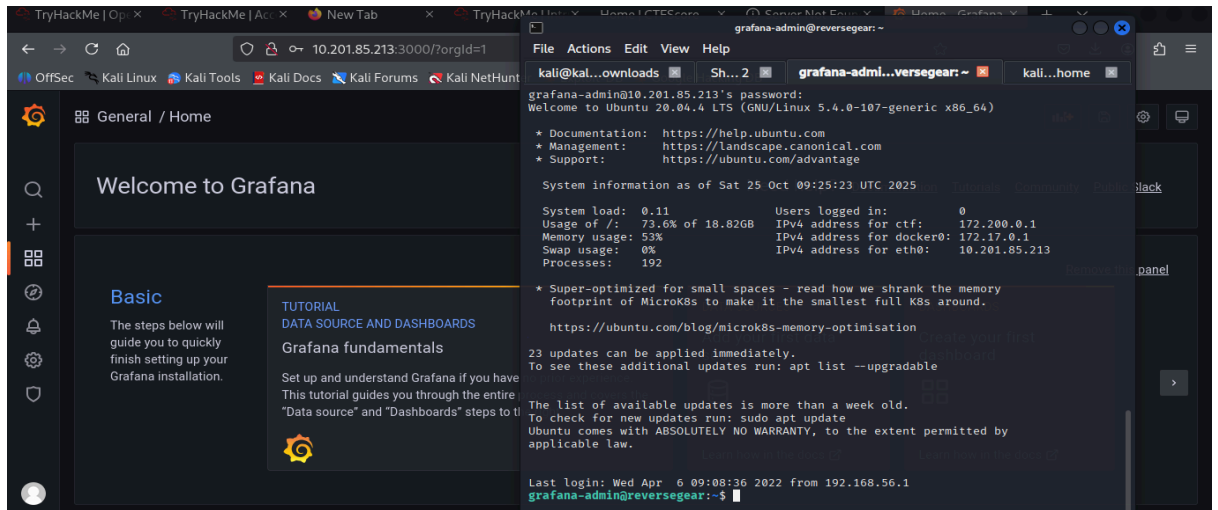
I found that I could read sensitive files like `grafana.ini`, which contains admin credentials.



Step 3: Credential Extraction and Initial Access

By downloading the `grafana.ini` file, I found the admin username and password. With this:

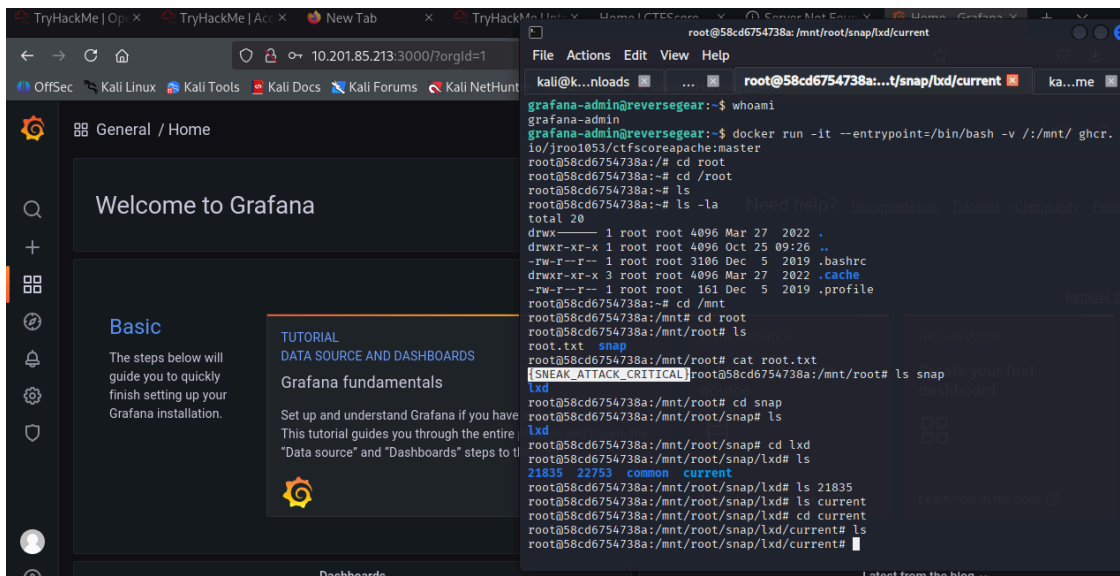
- Logged into the Grafana web interface using the discovered credentials `grafana-admin:GraphingTheWorld32`
- Gained access to administrative features that could be exploited for further control



Step 4: Privilege Escalation

Inside Grafana, I found the system was running inside a Docker container with a misconfiguration:

- The Docker socket was accessible from the container
- I mounted the host filesystem into a new Docker container
- This gave me access to the entire host system
- From there, I could escalate privileges to root and find the root flag
{SNEAK_ATTACK_CRITICAL}



IDS Alerts Observed

The screenshot shows a web browser with multiple tabs. The active tab is 'Alerts | CTFScore' at the URL '10.201.85.213:8000/alerts'. The page has a navigation bar with 'Dashboard', 'Alerts', and 'Logout'. The main content area is titled 'Scoring History' and contains a text block explaining that the page lists the last 10,000 alerts, including score-less ones. Below this is a search bar and a 'Show 10 entries' dropdown. A table of alerts is displayed with columns: Timestamp, Message, Category, Severity, Source, Targeted Asset, and Score. The table shows three alerts from 'Sat, 25 Oct 2025 08:29:03 GMT' related to 'ET SCAN Nmap Scripting Engine User-Agent Detected'. The scores are 5.33, 2.67, and 2.67 respectively.

Timestamp	Message	Category	Severity	Source	Targeted Asset	Score
Sat, 25 Oct 2025 08:29:03 GMT	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	Unknown Classtype	3	Suricata	172.200.0.30	5.33
Sat, 25 Oct 2025 08:29:03 GMT	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	Unknown Classtype	3	Suricata	172.200.0.10	2.67
Sat, 25 Oct 2025 08:29:03 GMT	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scri	Unknown		Suricata	172.200.0.10	2.67

During the process, some actions like file reads triggered alerts from the IDS (e.g., Wazuh IDS). This demonstrated the importance of monitoring unusual file access and unexpected administrative actions. However, by using stealthy commands and low-volume scanning, I minimized detection.

Recommendations

To avoid real-world scenarios like this:

- Harden web applications to prevent arbitrary file reads
- Protect and restrict access to configuration files
- Avoid mounting host filesystems inside Docker containers
- Use secrets management tools instead of storing plain credentials
- Monitor system logs and file access alongside IDS alerts for suspicious behavior

Conclusion

The IDS Evasion room provided practical exposure to how IDS can be bypassed by careful scanning and exploitation methods. With container misconfigurations and leaked credentials, attackers can gain full system control without triggering high-severity alerts. This room emphasizes the critical need for secure configurations and layered monitoring.